



WILLIAM STALLINGS

EFFECTIVE CYBERSECURITY

1ST EDITION

CHAPTER 3

Information Risk Assessment



Term	ISO 27005 Definition
asset	Anything that has value to the organization and which therefore requires protection
im pact	Adverse change to the level of business objectives achieved ISO 27005 uses consequence SP800-30 uses im pact level and equivalently im pact value
event	Occurrence or change of a particular set of circumstances
threat	Potential cause of an unwanted incident, which may result in harm to a system or organization
vulnerability	Weakness of an asset or control that can be exploited by one or more threats
threat action	A realization of a threat, i.e., an occurrence in which vulnerability is exploited as the result of either an accidental event or an intentional act.
threat agent	A system entity that performs a threat action, or an event that results in a threat action.
security incident	Adverse event whereby some aspect of security could be threatened
risk	A combination of the consequences of an information security event and the associated likelihood of occurrence.
likelihood	Chance of something happening, especially likelihood of a security incident. X.1055 uses risk of exposure (RoE)
level of risk	Magnitude of a risk, expressed in terms of the combination of consequences and their likelihood
security control	The management, operational, and technical countermeasures prescribed to protect the confidentiality, integrity, and availability or other security property of an asset.
residual risk	Risk remaining after risk treatment
risk identification	Process of finding, recognizing and describing risks
risk analysis	Process to comprehend the nature of risk and to determine the level of risk
risk criteria	Terms of reference against which the significance of a risk is evaluated
risk evaluation	Process of comparing the results of risk analysis with risk criteria to determine whether the risk and/or its magnitude are acceptable or tolerable.
risk assessm ent	Overall process of risk identification, risk analysis, and risk evaluation
risk treatm ent	Process to modify risk SP800-30 uses risk response
risk m anagem ent	Coordinated activities to direct and control an organization with regard to risk

Table 3.1

Information Security Risk Terminology

(Table is on pages 75-76 in the textbook)

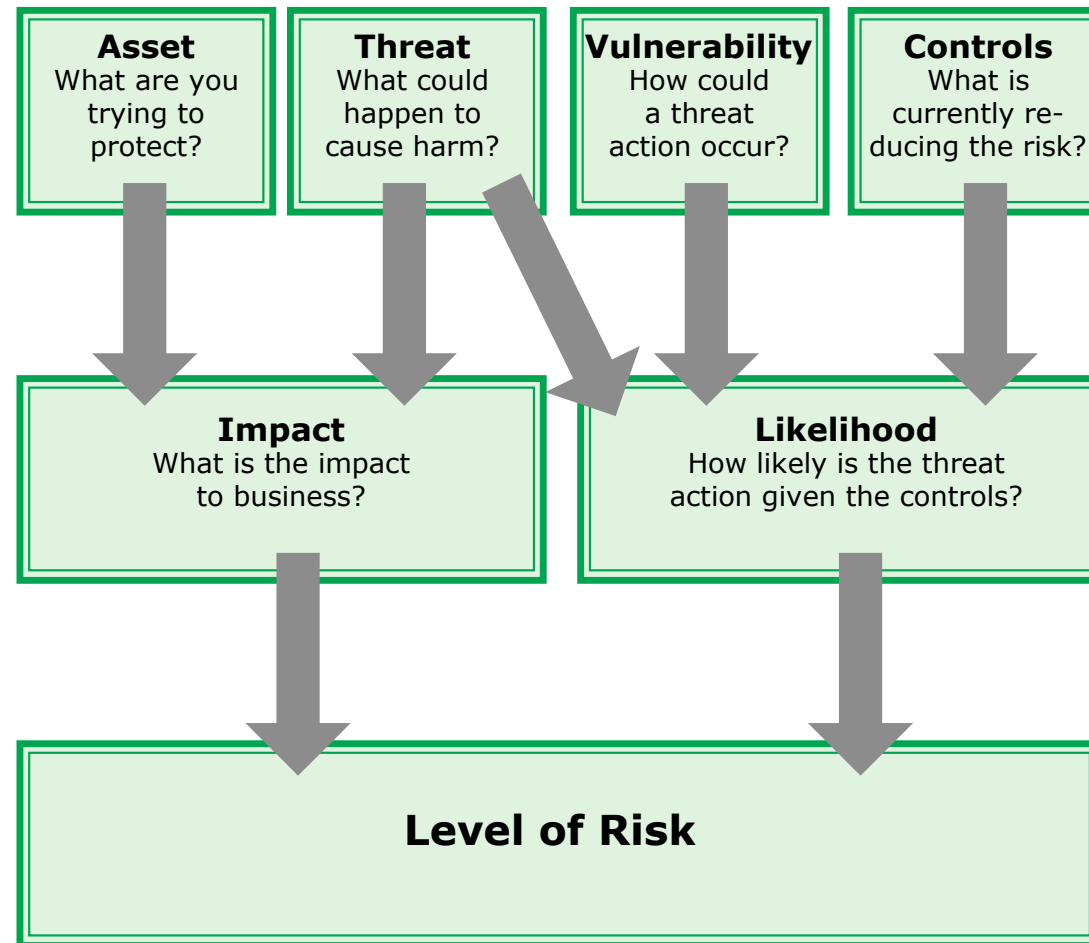


Figure 3.1 Determining Information Security Risk

IMPACT

- Consider two elements in determining impact:
 - Assets
 - Develop an inventory of the organization's assets, which includes an itemization of the assets and an assigned value for each asset
 - These include intangible assets such as reputation and goodwill, as well as tangible assets, such as databases, equipment, business plan, and personnel
 - Threats
 - For each asset, determine the possible threats that could reduce the value of that asset
- **Then, for each asset, determine the impact to the business, in terms of cost or lost value, of a threat action occurring**

LIKELIHOOD

- Consider three elements in determining likelihood:
 - Threat
 - For each asset, determine which threats are relevant and need to be considered
 - Vulnerability
 - For each threat to an asset, determine the level of vulnerability to the threat (that is, determine specifically for an asset how a threat action could be achieved)
 - Controls
 - Determine what security **controls are currently in place** to reduce the risk
- Determine **how likely it is that a threat action will cause harm** based on the likelihood of a threat action and the effectiveness of the corresponding controls that are in place

IMPACT - LIKELIHOOD

The level of risk is determined as the combination of the **cost** of the threat occurring combined **with the likelihood** of the threat occurring



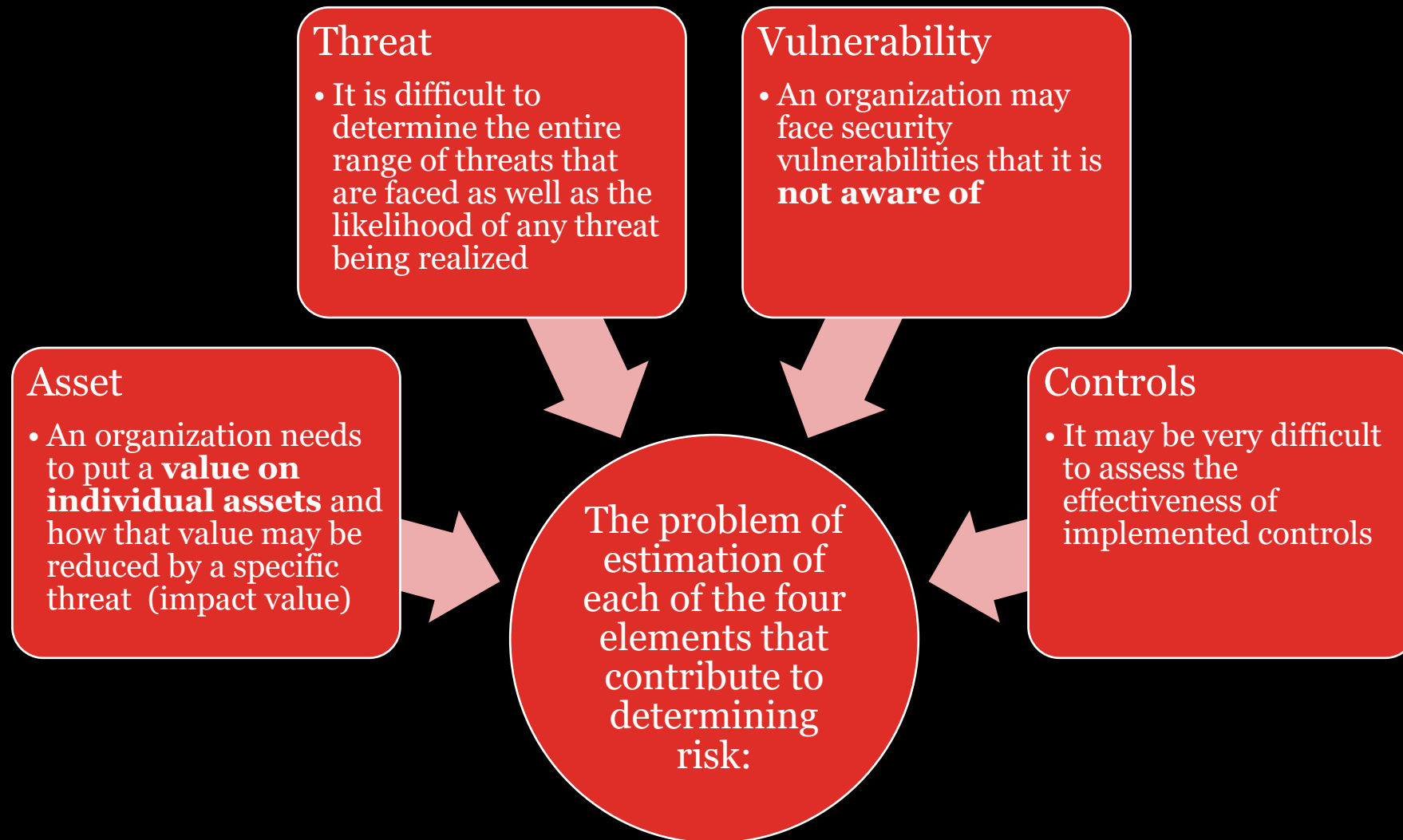
RISK ASSESSMENT CHALLENGES

Challenges that an organization faces in determining the level of risk fall into two categories:

1. The difficulty of estimating
2. The difficulty of predicting



PROBLEM OF ESTIMATION



PREDICTING FUTURE CONDITIONS

Another challenge in risk assessment is the difficulty of predicting future conditions

Asset

Changes in the value of an organization's assets complicate the effort to estimate the impact of a security threat. Company expansion, software or hardware upgrades, relocation, and a host of other factors may come into play

Threat

It is difficult enough to assess the current threat capability and intentions of potential adversaries and future projections are even more subject to uncertainty. Without complete knowledge of the threat, it is impossible to provide a precise assessment of impact

Vulnerability

Changes within the organization or its IT assets may create unexpected vulnerabilities. (i.e. if an organization migrates a substantial portion of its data assets to a cloud service provider, the degree of vulnerability of that provider may not be known to the organization with a high level of confidence)

Controls

New technologies, software techniques, or networking protocols may provide opportunities for strengthening an organization's defenses. It is difficult to predict the nature of these new opportunities, much less their cost, and so resource allocation over the planning period may not be optimal

RISK MANAGEMENT

- National Institute of Standards and Technology (NIST) Cybersecurity SP 800-37, *Risk Management Framework for Information Systems and Organizations*, states that:
 - Risk management **includes a disciplined, structured, and flexible process** for organizational asset valuation; security and privacy control selection, implementation, and assessment; system and control authorizations; and continuous monitoring
 - It also includes enterprise-level activities to help **better prepare organizations** to execute a risk management framework at the system level.

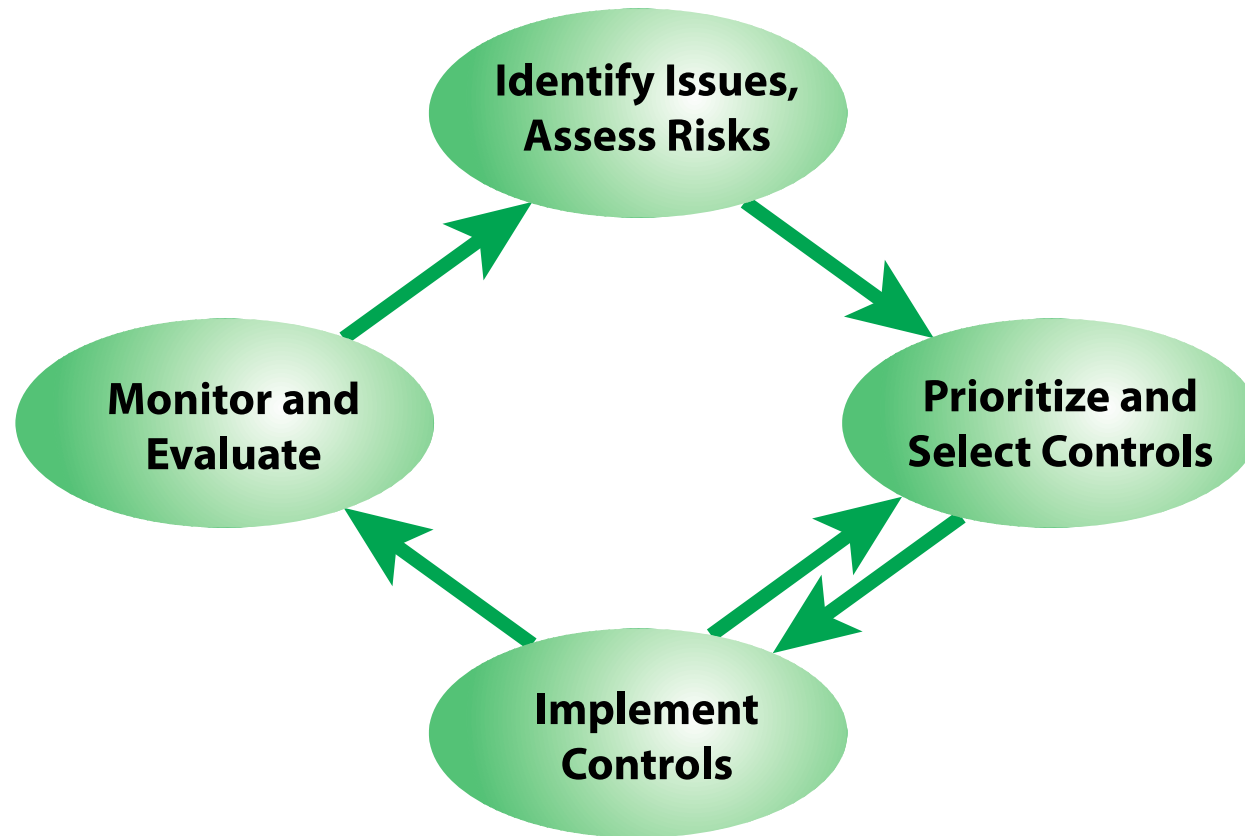


Figure 3.2 Risk Management Life Cycle

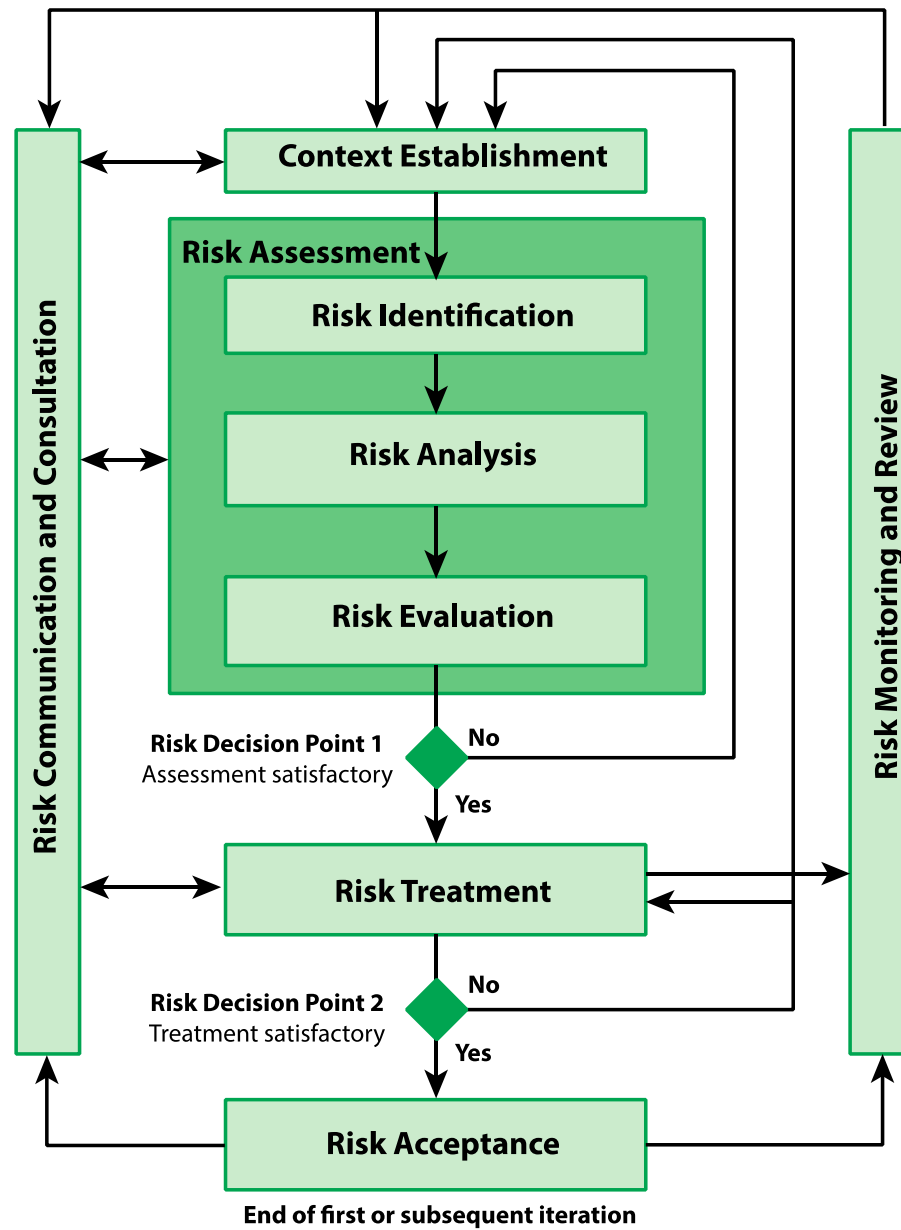
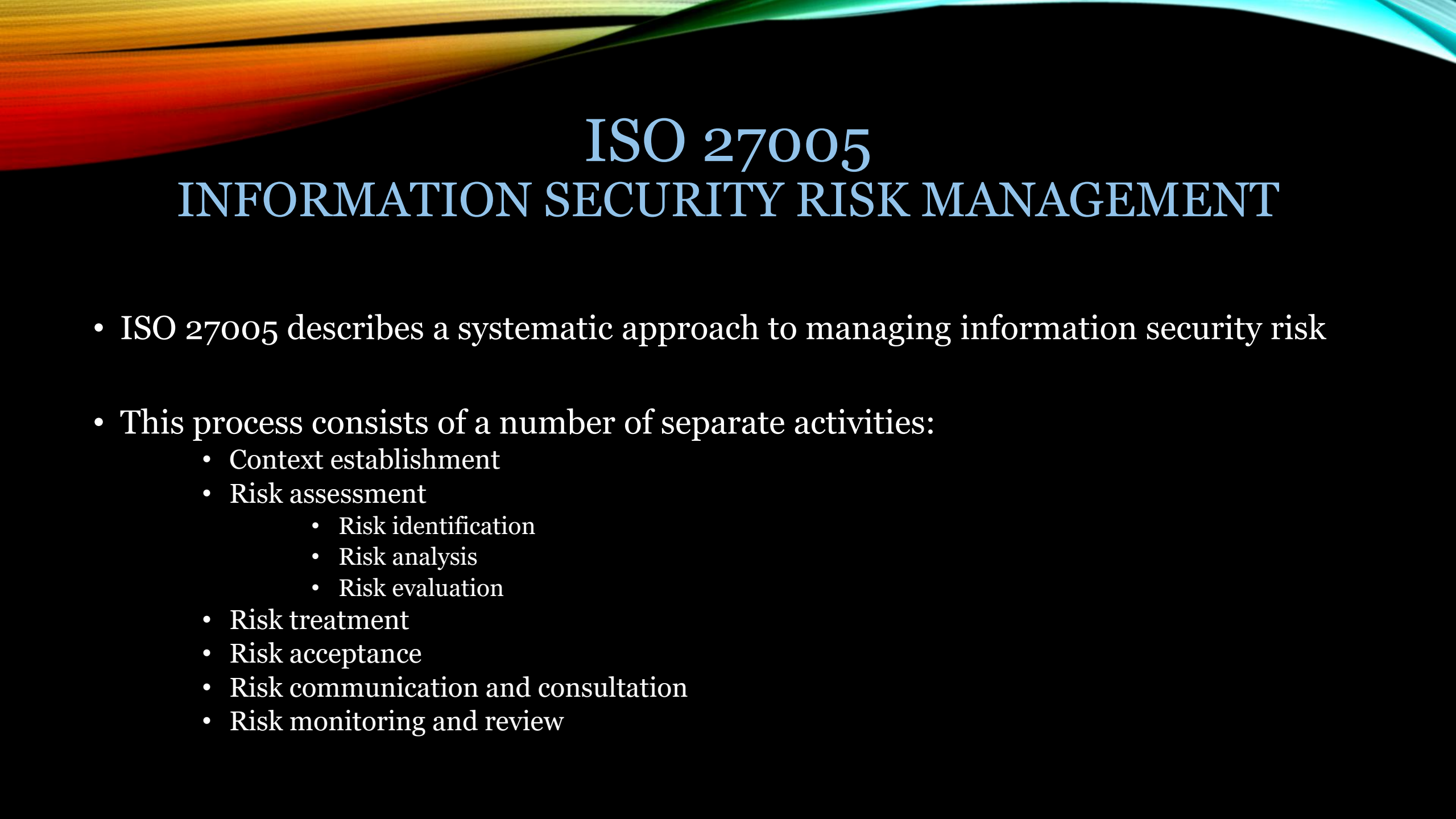


Figure 3.3 ISO 27005 Risk Management Process

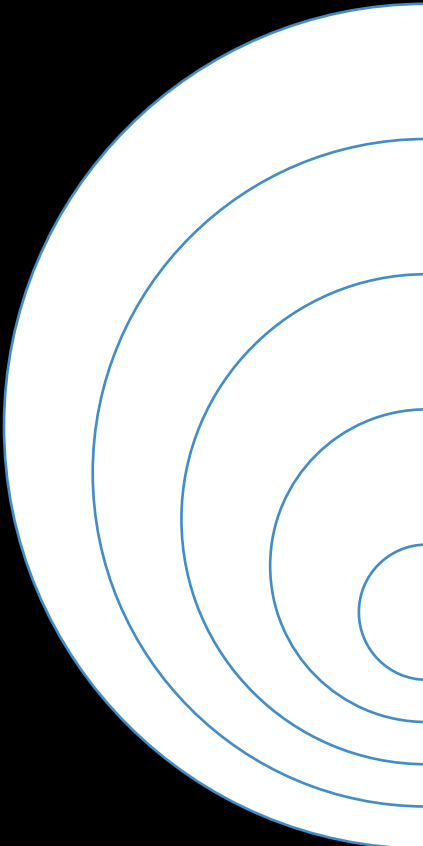


ISO 27005

INFORMATION SECURITY RISK MANAGEMENT

- ISO 27005 describes a systematic approach to managing information security risk
- This process consists of a number of separate activities:
 - Context establishment
 - Risk assessment
 - Risk identification
 - Risk analysis
 - Risk evaluation
 - Risk treatment
 - Risk acceptance
 - Risk communication and consultation
 - Risk monitoring and review

ASSET IDENTIFICATION



A first step in risk assessment is to document and determine values for the organization's assets

An asset is anything of value to the business that requires protection, including hardware, software, information, and business assets

The challenge is to develop a uniform way of documenting the assets, the security implications of each, and the costs associated with security incidents related to each

Asset valuation relates directly to business needs

The input for asset and custodians of assets **valuation needs to be provided by owners , not by members of the risk assessment team**



HARDWARE ASSETS

- Hardware assets include servers, workstations, laptops, mobile devices, removable media, networking and telecommunications equipment, and peripheral equipment
- Key concerns are loss of a device, through theft or damage, and lack of availability of the device for an extended period
- Another concern is device malfunction, due to deliberate malfunction or other causes
- Asset valuation needs to take into account **the replacement cost of the hardware**, disruption losses, and recovery expenses

SOFTWARE ASSETS

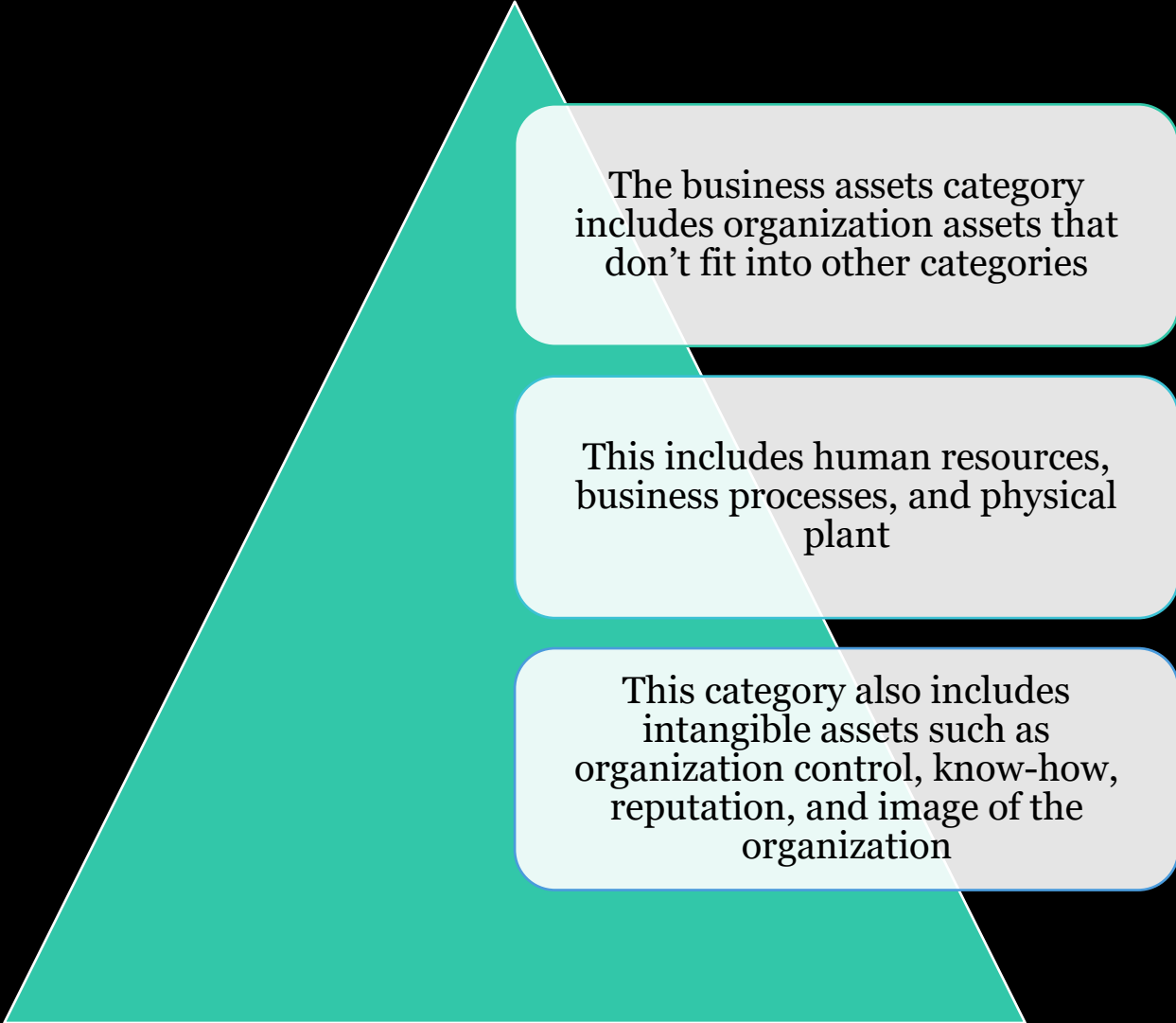
Software assets include applications, operating systems and other system software, **virtual machine** and **container virtualization** software, software for **software-defined networking (SDN)** and **network function virtualization (NFV)**, database management systems, file systems, and client and server software

Availability is a key consideration here, and asset valuation must take account of disruption losses and recovery expenses

INFORMATION ASSETS

- Information assets comprise the information stored in databases and file systems, both on-premises and remotely in the cloud
- ITU-T X.1055 lists the following as types of information assets in a telecommunications or network environment:
 - Communication data
 - Routing information
 - Subscriber information
 - Blacklist information
 - Registered service information
 - Operational information
 - Trouble information
 - Configuration information
 - Customer calling patterns
 - Customer geographic locations
 - Traffic statistical information
 - Contracts and agreements
 - System documentation
 - Research information
 - User manuals
 - Customer information
 - Training materials
 - Billing information
 - Operational or support procedures
 - Business continuity plans
 - Emergency plan fallback arrangements
 - Audit trails and achieved information

BUSINESS ASSETS



The business assets category includes organization assets that don't fit into other categories

This includes human resources, business processes, and physical plant

This category also includes intangible assets such as organization control, know-how, reputation, and image of the organization

	<i>Example: Customer Contact Information</i>	Info type 1	Info type 2	
Cost of revelation (Confidentiality)	<i>Medium</i>			
Cost to verify information (Integrity)	<i>High</i>			
Cost of lost access (Availability)	<i>High.</i>			
Cost of lost work	<i>High</i>			
Fines, penalties, customer notification	<i>Medium</i>			
Other legal costs	<i>Low</i>			
Reputation / public Relations costs	<i>High</i>			
Cost to identify and repair problem	<i>High</i>			
Overall Score:	<i>High</i>			

Table 3.3

**Identify and
Prioritize
Information
Types**

(Table is on page 87 in the textbook)

ASSET REGISTER

- In order to effectively protect assets, an organization needs to provide a systematic method of documenting assets and their security implication
- This is done in an asset register that documents important security-related information for each asset
- Examples of items that may be included are:
 - Asset name/description
 - Asset type asset class
 - Information risk assessment
 - Information assets
 - Asset owner
 - Asset custodian
 - Location
 - Function/business process
 - Data type/classification
 - Asset value classification
 - Disaster recovery priority
 - Exposure level



Asset Name/ Description	Asset Classification	Disaster Recovery Priority	Description	Exposure Level
Personnel	High	1	Employees	Medium
Client PII	High	1	Personally Identifiable Information	Low
Production Web server	Medium	1	Company primary web site (no sensitive data)	High

Table 3.4
Example Asset Register

THREAT IDENTIFICATION

- Threat identification is the process of identifying sources with the potential to harm system assets
- Threat sources are categorized into three areas:
 - **Environmental**
 - Examples include floods, earthquakes, tornadoes, landslides, avalanches, electrical storms, and power failure
 - **Business resources**
 - Examples include equipment failure, supply chain disruption, and unintentional harm caused by employees
 - **Hostile actors**
 - Examples include hackers, hacktivists, insider threats, criminals, and nation-state actors

STRIDE THREAT MODEL

STRIDE is a threat classification system developed by Microsoft that is a useful way of categorizing attacks that arise from deliberate actions

Spoofing identity

An example is illegally accessing and then using another user's authentication information, such as username and password

Security controls to counter such threats are in the area of *authentication*

Involves the malicious modification of data

Tampering with data

Relevant security controls are in the area of *integrity*

Repudiation

Repudiation threats are associated with users who deny performing an action without other parties having any way to prove otherwise

Relevant security controls are in the area of *non-repudiation*, which refers to the ability of a system to counter repudiation threats

Information disclosure

Threats that involve the exposure of information to individuals who are not supposed to have access to it

Relevant security controls are in the area of *confidentiality*

Denial of service (DoS)

Attacks that deny service to valid users

Relevant security controls are in the area of *availability*

Elevation of privilege

An unprivileged user gains privileged access and thereby has sufficient access to compromise or destroy the entire system; an attacker has effectively penetrated all system defenses and become part of the trusted system itself

Relevant security controls are in the area of *authorization*

THREAT TYPES

- Malware
- Virus
- Worm
- Ransomware
- Spam
- Logic bomb
- Trojan horse
- Backdoor (trapdoor)
- Mobile code
- Exploit
- Exploit kit
- Downloader
- Dropper
- Auto-rooter
- Kit (virus generator)
- Spammer program
- Flooder
- Keyloggers
- Rootkit
- Zombie or bot
- Spyware
- Adware
- Remote access attacks
- Denial-of-service (DoS)
- Distributed denial-of-service (DDoS) attack
- DNS attacks
- Hacker or cracker
- Injection flaw
- Code injection
- Social engineering
- Phishing
- Password attack
- Website exploit

SOURCES OF INFORMATION

It is difficult to get reliable information on past events and to assess future trends for a variety of reasons, including:

Organizations are often reluctant to report security events in an effort to save corporate image, avoid liability costs, and, in the case of responsible management and security personnel, avoid career damage

Some attacks may be carried out or at least attempted without being detected by the victim until much later, if ever

Threats continue to evolve as adversaries adapt to new security controls and discover new techniques

Thus, keeping informed on threats is an ongoing and never-ending battle

Three important categories of threat information sources are:

In-house experience

- An important source of information on threats is the experience an organization has already had on identifying attempted and successful attacks on its assets

Security alert services

- These are concerned with detecting threats as they develop to enable organizations to patch code, change practices, or otherwise react to prevent a threat from being realized

Global threat surveys

- Of great value for threat identification is the various global threat surveys that are readily available

VERIZON DATA BREACH INVESTIGATIONS REPORT (DBIR)

This authoritative and highly respected annual report is perhaps the most important source of information that an organization can consult

The results in the 2018 report are based on data from more than 53,000 security incidents and over 2,200 data compromises from 65 countries and 67 organizations

Results are broken down by 20 industry sectors such as accommodation, entertainment, finance, healthcare, manufacturing, public, and utilities

Further, threats are broken down along three dimensions

- Pattern
 - This includes DoS, privilege misuse, lost and stolen assets, point of sale, miscellaneous errors, web attacks, crimeware, payment card skimmers, and cyber-espionage
- Action
 - This includes hacking, malware, social breach, error misuse, physical breach, and environmental-based damage
- Asset
 - This includes servers, media, user devices, persons, networks, kiosks/terminals and embedded devices (Internet of Things [IoT] devices)

DATA BREACH INVESTIGATION REPORT

- The DBIR defines a *security incident* as a security event that compromises the integrity, confidentiality, or availability of an information asset
- The DBIR defines a *breach* as an incident that results in the confirmed disclosure—not just potential exposure—of data to an unauthorized party
- The report also summarizes, with data, key aspects of the attack, including:
 - Actors
 - Broken down into the categories outsiders, internal actors, state-affiliated actors, multiple parties, partners, and organized criminal groups
 - Tactics
 - Includes hacking, malware, leveraging stolen and/or weak passwords, social attacks, errors, privilege misuse, and physical actions
 - Other common factors
 - Includes malware installed via malicious email attachments, financially motivated breaches related to espionage and discovered by third parties
- Given the wealth of high-quality data, the DBIR is an essential tool in the threat identification process

THREAT HORIZON REPORT

- A useful complement to the DBIR is the annual Threat Horizon Report from the ISF
- This report differs from the DBIR in two ways:
- It is a more broad-brush treatment, identifying key threat trends rather than detailed threats and detailed target profiles
- **The Threat Horizon Report attempts to project the likely major threats of the next two years**
- *Threat Horizon 2019* highlights nine major threats, broken down into three challenging themes, that organizations can expect to face over the next two years as a result of increasing developments in technology
 - Disruption
 - Distortion
 - Deterioration

Disruption

- Likely due to an over-reliance on fragile connectivity requiring a seismic shift in the way business continuity is planned, practiced and implemented
- The major threats are:
 - Premeditated Internet outages bringing trade to its knees
 - Ransomware hijacks on the IoT
 - Privileged insiders being coerced into giving up the crown jewels

Distortion

- As trust in the integrity of information is lost, the monitoring of access and changes to sensitive information becomes critical, as does the development of complex incident management procedures
- The major threats are:
 - Automated misinformation gaining instant credibility
 - Falsified information compromising performance
 - Subverted blockchains shattering trust

Deterioration

- Controls may be eroded by regulations and technology bringing a heightened focus on risk assessment and management in light of regulatory changes and the increased prevalence of artificial intelligence in everyday technology
- The major threats are:
 - Surveillance laws exposing corporate secrets
 - Privacy regulations impeding the monitoring of insider threats
 - A headlong rush to deploy artificial intelligence (AI) leading to unexpected outcomes

Table 3.5 Top Cybersecurity Threats Reported by ENISA

Threat	Trend	Threat	Trend
1. Malware	➡	9. Insider threat (malicious, accidental)	➡
2. Web based attacks	⬆	10. Physical manipulation/damage/ theft/loss	➡
3. Web application attacks	⬆	11. Data breaches	⬆
4. Phishing	⬆	12. Identity theft	⬆
5. Spam	⬆	13. Information leakage	⬆
6. Denial of service	⬆	14. Exploit kits	⬇
7. Ransomware	⬆	15. Cyber espionage	⬆
8. Botnets	⬆		

Trend: ⬇ Declining, ➡ Stable, ⬆ Increasing